Security Assessment Report

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. | Date: 2026-10-16 | Repository: fusionhawk/Anarock, main (application code as of 21cf217; HEAD d2929ad)

1. Executive summary

Overall risk: **High**. 16 items: 1 critical, 3 high, 8 medium, 3 low, 1 informational. The most important issues are the outdated Next.js with a critical advisory, an unprotected and unvalidated public endpoint (/api/lead2) that writes client-chosen values into production CRM, a rate limiter that is trivially bypassed, and duplicate-lead handling that lets the public overwrite existing CRM leads.

Activities performed (raw logs in reports/evidence/): (1) **GitHub pull** - git fetch/pull of fusionhawk/Anarock main, HEAD recorded (01_git_pull.log); (2) **Scope document** fetched from Slack (F0BP8478AE4) and compared with the repo copy - identical (11); (3) **Zoho CRM** inspected live, read-only, via the AnarockCRM connector: org, modules, Leads/Properties field metadata, record counts, COQL reads (10); (4) **Security checks**: npm audit (02); secret scan of all 131 tracked files and the full git history, 46 commits and 702,433 added lines (05); Semgrep SAST with 108 rules over 105 files, scanner proven on a known-bad canary file (06); GitHub secret-scanning attempted (07); manual review of all active API/lib code (about 5,000 lines, comments stripped); (5) **Build checks**: npm ci, next lint, next build (02-04); (6) **Request tests**: 79 scripted HTTP checks against the running app (08, script run_api_tests.sh); (7) **Browser tests**: 103 Playwright checks at 1366px and 375px including axe-core accessibility, link crawl and cookie checks (09, script run_browser_tests.js). The app ran locally with **no Zoho/Catalyst credentials**, so no request could reach production CRM.

Limitations: no credentials or CRM sandbox were available, so flows that need live Data Store, Stratus or CRM writes (listing results, detail data, lead creation end-to-end, duplicate-lead behaviour, KYC and market-stats data) could not be executed and are marked *Blocked*. SAST found no injection-class issues, but the main findings here are logic and design flaws that pattern-based tools do not detect. No load testing or external penetration test was done.

2. Findings

ID	Severity	Finding	How verified / evidence	Recommendation
S-01	Critical	Next.js 14.2.35 and the eslint-config-next / tailwindcss chain carry known advisories: npm audit = 13 (1 critical, 10 high, 2 moderate). Lockfile is also out of sync with package.json (npm ci fails), so builds are not reproducible.	Executed: npm audit; npm ci (fails: missing @emnapi/core, @emnapi/runtime in lock)	Upgrade Next.js to a patched release, regenerate and commit the lockfile, run npm audit in CI.
S-02	High	/api/lead2 (home-page 'post a requirement' form) has no rate limit, no content-type or body-size check, no honeypot, and no phone/email format validation. It also writes client-supplied leadSource, leadStatus and subLeadSource straight into CRM Lead_Source / Lead_Status / Sublead_Source, and triggers CRM workflows.	Runtime: 15 consecutive POSTs from one client all processed (no 429); phone 'not-a-phone', email 'notanemail' and a text/plain body were accepted and passed to the CRM-token step. Code: lead2/route.js:327-329	Reuse the validation of /api/leads; whitelist source/status server-side; add CAPTCHA + throttling at the API Gateway.
S-03	High	Rate limiting on /api/leads and /api/lead3 is keyed on the client-supplied X-Forwarded-For header and held in a per-instance in-memory Map that is never purged. Spoofing the header bypasses it entirely, and the Map grows without bound.	Runtime: same client blocked on request 11 (429); 12 requests with a different X-Forwarded-For each returned 400, never 429. Code: leads/route.js:95-139	Use the platform-trusted client IP, a shared store, and API Gateway throttling (in scope per SoW 3.2).

ID	Severity	Finding	How verified / evidence	Recommendation
S-04	High	Duplicate-lead handling lets an anonymous caller overwrite fields of an existing CRM lead (PUT with attacker-supplied values, workflows triggered) and the response reveals whether the phone/email already exists plus the CRM lead ID and owner team.	Code: leads/route.js:421-530 (PUT to /crm/v8/Leads/{id}), response fields duplicate, priority, leadId, leadOwnerTeam at :784-799; same pattern in lead3	Never update an existing lead from public input: create a note/task instead; return a generic response without IDs.
S-05	Medium	Public API responses expose internal error text. Unauthenticated callers can read configuration details such as missing environment-variable names.	Runtime (08, 09): GET /api/properties -> 500 {'error':'CATALYST_PROJECT_ID is missing'} and the same text is rendered to users on /properties, /kyc and detail pages; same on /properties/{id}, suggestions, market-stats, kyc; /api/cities -> 'ZOHO_CLIENT_ID is missing'. Code fallback JSON.stringify(error)	Return generic messages; log details server-side only.
S-06	Medium	No security headers: no CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy; X-Powered-By is exposed; no Origin/CSRF check on POST routes.	Runtime: curl -I on / showed only Cache-Control and X-Powered-By; next.config.mjs has no headers()	Add headers() in next.config, set poweredByHeader:false, add Origin checks on POST.
S-07	Medium	Public property API returns the entire Data Store row (object spread in propertyMapper) and, when no page params are sent, the whole catalogue in one response. It explicitly includes CRM-internal fields such as achievableRent and crmID; CRM Properties also holds SPOC_Name / SPOC_Number, which would be exposed if synced to the Data Store.	Code: propertyMapper.js (...row, achievableRent, crmID, creatorID), properties/route.js pageSize defaults to total; CRM field list (SPOC_Name, SPOC_Number, Achievable_Rent)	Whitelist public fields in a DTO; cap pageSize; confirm Data Store columns exclude contact and internal pricing data.
S-08	Medium	The public layer does not enforce 'Published/approved'. Every Data Store row is served. SoW requires only approved, validated properties be exposed; the sync that should enforce this is not in the repo.	Code: propertiesCache.js maps all rows, no status filter. CRM: 293 of 7,279 Properties have Push_to_Website = true	Add an explicit published flag check in the app and in the sync function.
S-09	Medium	Property detail page title is built from the URL slug, so any text can be injected into a page title that is served 200 and indexable (content spoofing / SEO poisoning); unknown IDs are not 404.	Runtime: /properties/abc/xyz -> HTTP 200, title 'xyz | Anarock'. Code: properties/[id]/[name]/page.js generateMetadata	Fetch the property server-side, derive title from data, return notFound() when missing, redirect to canonical slug.
S-10	Medium	Long-lived Zoho OAuth refresh tokens (CRM and Catalyst) are held in app environment and used for all server calls; scope and rotation are not documented. Catalyst defaults to the 'Production' environment and a hard-coded table ID when env vars are absent, while .catalystrc contains only a Development environment.	Code: catalyst.js:7-9, 33-36; .catalystrc	Least-privilege scopes, separate dev/prod credentials, fail closed when env is missing.
S-11	Low	/api/location: throttle is not serialised (concurrent requests read the same timestamp, so Nominatim's 1 req/s policy can be exceeded); unbounded in-memory cache; precise user coordinates are sent to a third party; malformed JSON returns 500; failures return HTTP 200.	Code: location/route.js:20-30; Runtime: malformed body -> 500	Serialise with a lock, bound the cache, add consent notice (DPDP), return 4xx for bad input.
S-12	Low	Catalyst Web SDK 4.6.2 is loaded from a third-party CDN on every page without Subresource Integrity and no usage of the SDK was found in the client code.	Code: layout.js:79; grep for catalyst usage found none outside server libs	Remove if unused, otherwise add SRI and restrict via CSP.

ID	Severity	Finding	How verified / evidence	Recommendation
S-13	Low	Raw user search 'prompt' text is written to server logs; verbose console.log/console.error output in 10 files including full error objects and stacks.	Code: properties/route.js:587-592; grep	Remove or redact; use structured logging.
S-14	Medium	Repository hygiene: GitHub Advanced Security (secret scanning / push protection) is not enabled on fusionhawk/Anarock, and .gitignore files only ignore '.env*.local' (root) and '.env.local' (anarock/), so a plain .env or .env.production would be committed. Secret scan of the working tree and full history found nothing today.	Executed: GitHub secret-scanning call returned 'Repository does not have GitHub Advanced Security enabled' (07); .gitignore review; history scan clean (05)	Enable secret scanning and push protection; ignore .env and .env.*; add a pre-commit scanner.
S-15	Medium	Public lead endpoints can be driven from any website: /api/lead2 accepts a cross-origin text/plain POST (no CORS preflight needed), so any third-party page can make visitors' browsers submit leads. The 50KB body limit in /api/leads and /api/lead3 relies on Content-Length and is skipped by chunked requests.	Executed: lead2 cross-origin text/plain POST processed (500 at CRM stage, not 415); 60KB chunked POST to /api/leads parsed (400) instead of 413 (08)	Enforce Origin checks, JSON-only content type and a streaming body-size limit.
S-16	Info	Positive controls verified: honeypot returns a fake success to bots; /api/leads and /api/lead3 enforce 415 on wrong content-type, length limits, phone and email validation, and 429 after 10 requests/min per client; no secrets found in the repository (.catalystrc holds IDs only); breadcrumb JSON-LD is escaped; wishlist is client-side only.	Runtime tests, secret scan (0 hits in 131 files and 46 commits), Semgrep (0 findings, 108 rules)	Keep and reuse across all endpoints.

3. Dependency audit

Package	Severity	Affected range
next (installed 14.2.35)	critical	9.3.4-canary.0 - 16.3.0-preview.10
eslint-config-next	high	14.0.5-canary.0 - 15.0.0-rc.1
tailwindcss (transitive)	high	0.5.0 - 3.4.19
Total	13	1 critical, 10 high, 2 moderate

4. Priority remediation

1) Upgrade Next.js, fix lockfile. 2) Lock down /api/lead2 and the duplicate-update path, move throttling to a trusted layer (API Gateway + CAPTCHA). 3) Stop leaking errors and add security headers. 4) Whitelist public property fields and enforce the Published flag. 5) Review OAuth scopes and environment defaults.